ZCAS UNIVERSITY

SCHOOL OF COMPUTING, TECHNOLOGY, AND APPLIED SCIENCES

CIT3311 - COMPUTER AND NETWORK SECURITY

DEFERRED END OF SEMESTER 1 EXAMINATION

19TH JUNE, 2026

09:00 HRS - 17:00HRS

TIME ALLOWED : WRITING – THREE HOURS

READING – 5 MINUTES

INSTRUCTIONS:

1. Section A: This section is **compulsory** and must be attempted.
2. Sections B: Answer **THREE (3)** questions from this section.
3. This examination paper carries a total of **100 marks**.
4. Candidates must **not turn this page** until the invigilator tells them to do so.

SECTION A: Question 1 is compulsory and must be attempted.

A national e-government platform uses a hybrid cryptographic system combining symmetric encryption for bulk data, asymmetric encryption for key distribution, and a public-key exchange protocol to establish session keys between government ministries and citizens. The symmetric layer employs AES-256, while key establishment uses RSA and Diffie-Hellman. Answer all four parts below.

(i) The AES-256 encryption process involves several distinct transformation layers applied across multiple rounds. With reference to a standard AES-256 block diagram, identify and explain the seven components: the plaintext input block, the key expansion module, the initial round key addition, the SubBytes transformation, the ShiftRows operation, the MixColumns operation, and the final ciphertext output. For each component, state its role and its contribution to the overall security of the cipher. **[14 Marks]**

(ii) AES applies a slightly different transformation in its final round compared to all preceding rounds. State which transformation is omitted in the final round, explain the mathematical reason for this design decision, and demonstrate why omitting this transformation does not reduce the cipher's security strength. **[6 Marks]**

(iii)A government ministry wishes to generate an RSA key pair using the prime numbers $p = 13$ and $q = 17$. Generate the public key (Kp) and private key (Ks), ensuring that $e \neq d$. Show all working steps, including the computation of n, $\varphi(n)$, the selection of e, and the derivation of d using the Extended Euclidean Algorithm. **[10 Marks]**

(iv) Two government ministries wish to establish a shared encryption key using the Diffie-Hellman key exchange protocol. They publicly agree on a prime $p = 29$ and a primitive root $g = 3$. Ministry A selects a private key $a = 11$ and Ministry B selects a private key $b = 7$. Compute the shared secret key, showing all intermediate steps. State one man-in-the-middle vulnerability of this exchange and how it can be addressed. **[10 Marks]**

(Total: 40 Marks)

SECTION B: Attempt any THREE questions. Each question carries 20 marks.

Question 2

A national commercial bank is reviewing its information security posture following a series of customer account compromises. The bank's security team has identified weaknesses in how staff verify

customer identity over the phone, inconsistencies in how security principles are applied across branches, and gaps in employee awareness about manipulation techniques used by fraudsters. The bank's CISO has tasked you with producing a technical brief that addresses the following: explain the three factors of authentication with a practical banking example for each; define each principle of the CIA triad and, for each principle, identify one banking scenario in which it is violated and one technical control that enforces it; distinguish between threat, vulnerability, and risk - using a bank branch ATM network as your context, provide a concrete example of each and show how they combine to produce a specific risk; and describe two social engineering techniques that fraudsters typically use against bank employees, stating one organisational countermeasure for each. In your answer, also explain what multi-factor authentication is and why it is preferable to password-only authentication for online banking access.

[20 Marks]

Question 3

A hospital information system manages access to four resources: Medical Records, Pharmacy Database, Staff Payroll, and Research Portal. The system serves four categories of users: Admin, Doctor, Pharmacist, and Auditor. The permitted access operations are Read (R), Write (W), Execute (X), and Append (A). The hospital's access policy is as follows:

- Admin has full access to all four resources.
- Doctor has Read and Write access to Medical Records, Read and Append access to Research Portal, and Read-only access to Pharmacy Database.
- Pharmacist has Read and Write access to Pharmacy Database, and Read-only access to Medical Records. Pharmacist has no access to Staff Payroll or Research Portal.
- Auditor has Read-only access to Medical Records, Staff Payroll, and Research Portal, with no access to Pharmacy Database.

Construct a complete Access Control Matrix for the hospital system using the table provided below. After completing the matrix, identify two limitations of using an Access Control Matrix as the sole access control mechanism in a large hospital network with hundreds of users and resources, and for each limitation propose an alternative access control model or mechanism that addresses it.

Subject \ Object	**Medical Records**	**Pharmacy Database**	**Staff Payroll**	**Research Portal**
Admin				

Doctor				
Pharmacist				
Auditor				

(20 Marks)

Question 4

A regional airport has deployed a public Wi-Fi network for passengers alongside a secured internal wireless network for operations staff. A security consultant performing a wireless audit discovers that several access points are still running WEP, others are using WPA2-Personal with short passwords, WPS is enabled network-wide, and passengers are connecting over unencrypted HTTP to a fake access point advertising the airport's official SSID. Drawing on this scenario: compare WEP, WPA, WPA2, and WPA3 in a table across the dimensions of encryption algorithm, key length, authentication mechanism, and primary known vulnerability, then use your comparison to explain why the airport should migrate all access points to WPA3; explain how the KRACK attack exploits the WPA2 four-way handshake, describe the specific risk this poses to the airport's operations staff, and recommend two technical countermeasures; for each of the three security findings identified by the consultant — the fake access point, unencrypted HTTP traffic, and WPS being enabled — explain the exact threat it represents and prescribe a specific technical remedy; and design a four-part wireless security policy for the airport covering access point configuration, staff authentication, network segmentation between public and operational networks, and incident response procedures, justifying each policy element with reference to a specific wireless attack or threat.

(20 Marks)

Question 5

A large telecommunications company runs a security stack comprising TLS 1.3 with OCSP stapling for its customer portal, IKEv2/IPSec with EAP-TLS for its field engineer VPN, Kerberos with AES-256 for internal domain authentication, and DNSSEC for enterprise name resolution. A red team engagement reveals that an attacker who has established a foothold on an internal subnet is carrying out the following sequence of actions: first, the attacker presents a forged TLS certificate for an internal service whose legitimate certificate was recently revoked, and the OCSP check is bypassed because the client's OCSP implementation uses a cached response that has not yet expired; second, the attacker exploits an IKEv2 misconfiguration that permits the use of an outdated NULL authentication proposal during IKE_AUTH negotiation, allowing the attacker to establish an IPSec tunnel without presenting

valid credentials; third, the attacker extracts a Kerberos Ticket-Granting Ticket from memory on a compromised workstation and reuses it to authenticate to internal services, despite the legitimate user having changed their password after the initial compromise; fourth, the attacker injects malicious DNS responses that pass DNSSEC validation by exploiting a zone signing key that was rotated but whose old public key was not promptly removed from the chain of trust. For each of these four actions, identify the specific protocol mechanism that was bypassed or failed, explain how that failure enables the next step in the attacker's privilege escalation chain, specify the exact cryptographic or configuration fix that would have prevented it, and justify why the existing controls were insufficient to detect or block the attack at each stage.

(20 Marks)

END OF EXAMINATION